COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.6 · Access Controls

Mestre CyberSec · **Aula 4.6 — Access Controls** (7:49) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Modelos: ACL (por recurso, lista); MAC (obrigatório por CLASSIFICAÇÃO — militar, SELinux); DAC (discretionary — o DONO do arquivo decide, Windows FS); RBAC (por FUNÇÃO); ABAC (attributos); time-of-day restriction.

💡 Highlights que a prova CompTIA cobra

- MAC: o sistema decide por classificação (militar/SELinux)
- DAC: o DONO decide (Windows file permission)
- RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'permissions determined by data classification'=MAC

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.6 — Access Controls)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Lista de Controle de Acesso (ACL)

Lista associada a um recurso que especifica quais usuários ou grupos podem acessá-lo e quais operações podem realizar.

⚠️ ***Armadilha CompTIA:*** *Questões que mencionam permissões em arquivos, pastas ou recursos geralmente indicam ACL; ela pode implementar DAC (dono define) ou MAC (sistema define).*

• Controle de Acesso Obrigatório (MAC)

Modelo de controle de acesso em que o sistema impõe decisões de acesso com base em rótulos/classificações de segurança e habilitações do sujeito, não no proprietário do recurso.

⚠️ ***Armadilha CompTIA:*** *'Permissões determinadas por classificação de dados' = MAC. Exemplos: ambiente militar, SELinux. O dono do arquivo não define permissões.*

• Controle de Acesso Discricionário (DAC)

Modelo de controle de acesso em que o proprietário do recurso decide quem pode acessá-lo e quais permissões terá.

⚠️ ***Armadilha CompTIA:*** *Windows NTFS permissions são o exemplo clássico. Se o dono do arquivo concede acesso, é DAC; não confunda com MAC.*

• Controle de Acesso Baseado em Função (RBAC)

Modelo de controle de acesso que concede permissões com base na função ou cargo do usuário, não na identidade individual.

⚠️ ***Armadilha CompTIA:*** *Padrão enterprise: permissões por função/cargo. Se a questão menciona 'role' ou 'job function', escolha RBAC.*

• Controle de Acesso Baseado em Atributos (ABAC)

Modelo de controle de acesso que avalia múltiplos atributos (usuário, recurso, ambiente, ação) para tomar decisões dinâmicas de acesso.

⚠️ ***Armadilha CompTIA:*** *Se a decisão depende de atributos dinâmicos como hora, localização, departamento ou tipo de dispositivo, é ABAC.*

• Restrição por Horário do Dia (N/A)

Restrição de controle de acesso que permite ou nega acesso somente durante horários ou escalas especificados.

⚠️ ***Armadilha CompTIA:*** *Se a questão cita acesso permitido apenas em determinado horário, é time-of-day restriction; pode ser combinada com RBAC ou ABAC.*

• Linux com Segurança Aprimorada (SELinux)

Módulo de segurança do kernel Linux que impõe controle de acesso obrigatório usando rótulos e políticas.

⚠️ ***Armadilha CompTIA:*** *SELinux é exemplo clássico de MAC. Se aparecer SELinux, associe a labels/políticas obrigatórias, não a decisões do dono.*

• Classificação de Dados (N/A)

Processo de rotular dados com base na sensibilidade (ex.: público, confidencial, secreto) para determinar manuseio e requisitos de acesso.

⚠️ ***Armadilha CompTIA:*** *Em MAC, a classificação do dado e a habilitação do usuário determinam o acesso. A frase 'permissions determined by data classification' aponta para MAC.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de servidor de arquivos revisa como as permissões são atribuídas a uma pasta compartilhada. Cada pasta possui uma lista que especifica quais usuários e grupos individuais podem ler, gravar ou excluir arquivos, e o sistema operacional verifica essa lista sempre que um usuário abre um arquivo. Qual mecanismo de controle de acesso é descrito?

A) Lista de controle de acesso (ACL)

B) Controle de acesso obrigatório (MAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 2 · CENÁRIO DE EXAME

Uma agência de defesa armazena documentos rotulados como Confidencial, Secreto e Ultrassecreto. O sistema operacional compara o rótulo de cada documento com a credencial de segurança e a necessidade de conhecer do usuário antes de permitir o acesso. Nem o proprietário do documento nem o usuário podem alterar o rótulo ou ignorar a decisão. Qual modelo de controle de acesso está em uso?

A) Controle de acesso discricionário (DAC)

B) Controle de acesso obrigatório (MAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 3 · CENÁRIO DE EXAME

Um administrador Linux está fortalecendo um servidor web. O kernel aplica regras de política que restringem o processo do servidor web a tipos específicos de arquivos, mesmo que o processo seja executado como root. Os administradores não podem simplesmente alterar a propriedade do arquivo para conceder acesso mais amplo; a política precisa ser modificada. Qual tecnologia ou modelo está fornecendo esse controle?

A) Controle de acesso discricionário via permissões NTFS

B) Controle de acesso baseado em função via sudoers

C) Controle de acesso obrigatório do Security-Enhanced Linux (SELinux)

D) Controle de acesso baseado em atributos via atributos RADIUS

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de marketing armazena arquivos de projeto em um servidor Windows. O usuário que criou uma pasta pode decidir quais colegas podem acessá-la e pode alterar as permissões NTFS sem envolver um administrador de segurança. Qual modelo de controle de acesso isso descreve?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso discricionário (DAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 5 · CENÁRIO DE EXAME

O sistema de prontuário eletrônico de um hospital atribui permissões a funções de trabalho, como médico, enfermeiro e especialista em faturamento. Quando um funcionário passa do faturamento para a enfermagem, o administrador altera a atribuição do funcionário, e o sistema automaticamente concede as permissões de enfermagem e remove as de faturamento. Qual modelo está sendo usado?

A) Controle de acesso discricionário (DAC)

B) Controle de acesso obrigatório (MAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 6 · CENÁRIO DE EXAME

Um aplicativo em nuvem concede acesso a um documento somente quando o departamento do usuário corresponde à tag de projeto do documento, o usuário concluiu o treinamento exigido, a solicitação vem de um dispositivo gerenciado e o horário está dentro do aprovado. O mecanismo de autorização avalia todas essas condições em conjunto. Qual modelo de controle de acesso é este?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso discricionário (DAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

QUESTÃO 7 · CENÁRIO DE EXAME

Uma instalação usa leitores de crachá para contratados. O crachá de um contratado é válido para entrada apenas entre 07:00 e 18:00 em dias úteis. Às 20:00, o crachá é negado mesmo que o contratado ainda tenha a função e a credencial corretas. Qual restrição de controle de acesso está sendo aplicada?

A) Restrição de horário do dia

B) Controle de acesso obrigatório (MAC)

C) Controle de acesso discricionário (DAC)

D) Controle de acesso baseado em função (RBAC)

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de segurança de rede configura um conjunto de regras de firewall que permite ou nega tráfego com base no endereço IP de origem, endereço IP de destino e porta TCP. A lista é processada em ordem, e a primeira regra correspondente determina a ação. Qual conceito de controle de acesso é este?

A) Controle de acesso obrigatório (MAC)

B) Controle de acesso discricionário (DAC)

C) Lista de controle de acesso (ACL)

D) Controle de acesso baseado em função (RBAC)

QUESTÃO 9 · CENÁRIO DE EXAME

Uma instituição financeira deve limitar o acesso a um sistema de negociação a funções autorizadas durante o horário de negociação e bloquear o acesso em todos os outros horários. Quais dois conceitos de controle de acesso são combinados neste requisito?

A) MAC e DAC

B) RBAC e restrição de horário do dia

C) ABAC e SELinux

D) ACL e acesso discricionário

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto de segurança deve projetar o acesso para uma empresa multinacional. A decisão deve considerar o departamento do usuário, a atribuição de projeto, a classificação do recurso, a localização geográfica do usuário e se o dispositivo é compatível. Qual modelo de controle de acesso é mais apropriado?

A) Controle de acesso discricionário (DAC)

B) Controle de acesso obrigatório (MAC)

C) Controle de acesso baseado em função (RBAC)

D) Controle de acesso baseado em atributos (ABAC)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Lista de controle de acesso (ACL)
Uma ACL é uma lista anexada a um recurso que especifica quais sujeitos têm quais permissões. MAC usa rótulos e credenciais de segurança, RBAC usa funções de trabalho e ABAC usa múltiplos atributos, como departamento, dispositivo ou localização.

Questão 2: Alternativa B — Controle de acesso obrigatório (MAC)
O MAC aplica decisões de acesso usando rótulos de segurança e credenciais formais. O DAC permite que proprietários definam permissões, o RBAC usa funções de trabalho e o ABAC avalia atributos.

Questão 3: Alternativa C — Controle de acesso obrigatório do Security-Enhanced Linux (SELinux)
O SELinux implementa MAC usando políticas e rótulos de tipo, portanto os processos são confinados independentemente das permissões tradicionais de proprietário ou root. NTFS é DAC, sudoers é semelhante a RBAC e atributos RADIUS não são um sistema MAC do kernel.

Questão 4: Alternativa B — Controle de acesso discricionário (DAC)
O DAC permite que o proprietário do recurso determine as permissões de acesso. MAC usa rótulos e credenciais, RBAC usa funções e ABAC usa atributos.

Questão 5: Alternativa C — Controle de acesso baseado em função (RBAC)
O RBAC atribui permissões a funções, e os usuários recebem permissões por meio da associação a essas funções. DAC é controlado pelo proprietário, MAC é baseado em rótulos e credenciais e ABAC avalia muitos atributos.

Questão 6: Alternativa D — Controle de acesso baseado em atributos (ABAC)
O ABAC toma decisões avaliando atributos do sujeito, recurso, ação e ambiente. MAC, DAC e RBAC não combinam nativamente todas essas condições dinâmicas em uma única decisão de política.

Questão 7: Alternativa A — Restrição de horário do dia
Uma restrição de horário limita o acesso com base no horário ou agenda atual. MAC usa rótulos, DAC usa permissões do proprietário e RBAC usa funções; nenhum deles sozinho explica a negação às 20:00.

Questão 8: Alternativa C — Lista de controle de acesso (ACL)
Um conjunto de regras de firewall é uma forma de ACL: uma lista de entradas de permitir ou negar comparadas com atributos do tráfego. MAC usa rótulos, DAC usa permissões do proprietário e RBAC usa funções.

Questão 9: Alternativa B — RBAC e restrição de horário do dia
Funções autorizadas indicam RBAC, enquanto permitir acesso apenas durante o horário de negociação é uma restrição de horário. MAC e DAC, ABAC e SELinux, e ACL e DAC não descrevem com precisão esse requisito combinado de função e agenda.

Questão 10: Alternativa D — Controle de acesso baseado em atributos (ABAC)
O ABAC é projetado para avaliar múltiplos atributos do sujeito, recurso e ambiente em uma única decisão de política. DAC usa discrição do proprietário, MAC usa rótulos e credenciais e RBAC usa funções, mas o cenário exige condições mais amplas baseadas em atributos.